Null Session e ARP Poisoning

Analisi teorica e attività pratica in ambiente virtuale

Obiettivo della pratica

Con questa attività ho studiato due temi di sicurezza: la Null Session nei sistemi Windows e l'ARP Poisoning nelle reti locali IPv4. Ho analizzato il funzionamento, i rischi e le possibili contromisure. Nella parte pratica ho verificato la connettività tra le macchine virtuali, individuato gli host con Ettercap e osservato il traffico ARP con Wireshark, confrontando anche la tabella ARP di Windows prima e durante il test.

Ambiente di laboratorio

Ho utilizzato tre macchine virtuali: Kali Linux come sistema da cui eseguire le verifiche, Windows 10 come host di prova e pfSense come gateway della rete interna. Gli indirizzi osservati durante il laboratorio sono riportati nella tabella iniziale. Le macchine Kali e Windows risultavano collegate alla rete interna VirtualBox denominata intnet.

Prima delle verifiche ARP ho controllato la connettività. Dai risultati raccolti, Kali raggiungeva Windows (192.168.50.102) e il gateway (192.168.50.1); anche Windows raggiungeva il gateway.

Parte teorica — Null Session

Definizione e rischio

Durante lo studio della Null Session ho capito che si tratta di una connessione anonima che, in vecchi sistemi Windows o in configurazioni poco sicure, poteva consentire l'accesso ad alcuni servizi di rete senza inserire username e password. In determinate condizioni, un utente non autenticato poteva raccogliere informazioni su utenti, gruppi, sistemi o risorse condivise. Il rischio principale consiste quindi nella divulgazione di informazioni utili a preparare ulteriori tentativi di attacco.

Sistemi interessati
La Null Session è associata soprattutto a Windows NT, Windows 2000 e Windows XP e a configurazioni SMB che consentivano accessi anonimi. Anche sistemi server possono essere esposti se configurati in modo permissivo. I sistemi moderni includono controlli più efficaci, ma sistemi obsoleti e configurazioni errate possono mantenere il rischio.

Mitigazioni
- Limitare o disabilitare le connessioni anonime non necessarie.
- Verificare le autorizzazioni di cartelle, stampanti e condivisioni di rete.
- Configurare SMB secondo le raccomandazioni di sicurezza della versione utilizzata.
- Aggiornare i sistemi e sostituire quelli fuori supporto.
- Limitare le connessioni tramite firewall e segmentazione della rete.
- Monitorare i log per individuare accessi anonimi o attività insolite.

Nel material pratico che ho potuto ricostruire non è presente un output verificabile di un test Null Session. Per questo motivo, la relazione descrive la parte teorica ma non dichiara che una verifica pratica della Null Session sia stata completata.

Parte teorica — ARP Poisoning
ARP viene utilizzato nelle reti IPv4 locali per associare un indirizzo IP a un indirizzo MAC. Quando un computer deve inviare traffico al gateway, deve conoscere il suo MAC e può ottenere questa informazione tramite una richiesta ARP. Poiché ARP non autentica in modo nativo le risposte, un dispositivo presente sul segmento di rete può tentare di diffondere associazioni false. Se accettate dalla vittima, queste associazioni possono indirizzare parte del traffico verso il dispositivo sbagliato e creare le condizioni per un attacco Man-in-the-Middle (MITM).

Sistemi esposti
Il rischio non riguarda un solo sistema operativo: può interessare host Windows, Linux e macOS, server, workstation e alcuni dispositivi IoT collegati a una rete IPv4 locale. L'esposizione dipende dalla rete, dai controlli disponibili e dalla possibilità per un dispositivo non attendibile di comunicare sullo stesso segmento.

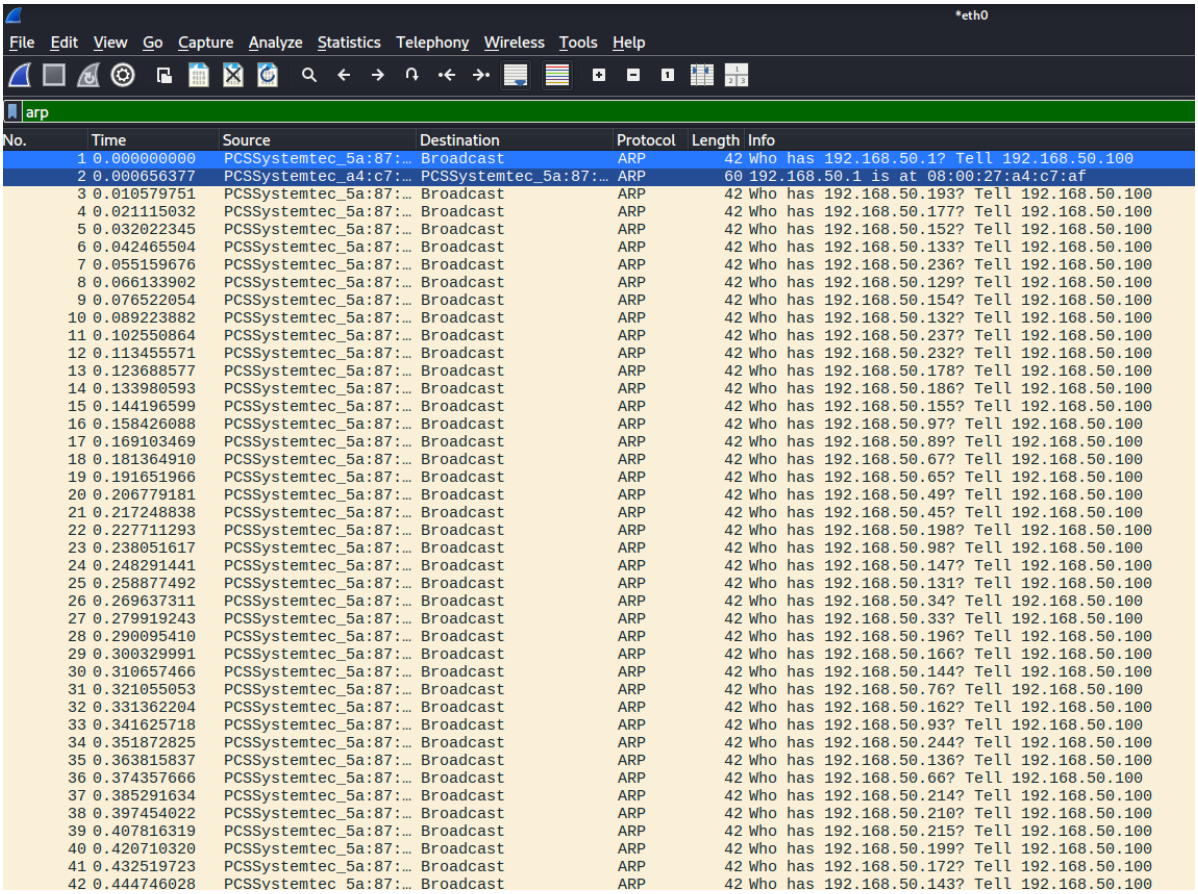
Contromisure

- Dynamic ARP Inspection (DAI), se supportata dagli switch, per controllare e bloccare messaggi ARP non attendibili.
- DHCP Snooping per fornire informazioni affidabili sulle assegnazioni DHCP utilizzabili da DAI.
- Associazioni ARP statiche in ambienti piccoli e controllati, tenendo conto della manutenzione necessaria.
- Monitoraggio con Wireshark o strumenti di rilevamento per individuare cambiamenti IP-MAC inattesi.
- Segmentazione della rete per ridurre la portata di eventuali attacchi.
- Uso di HTTPS, SSH e altri protocolli sicuri per proteggere riservatezza e integrità delle comunicazioni.
- Aggiornamento dei dispositivi e controllo degli accessi alla rete.

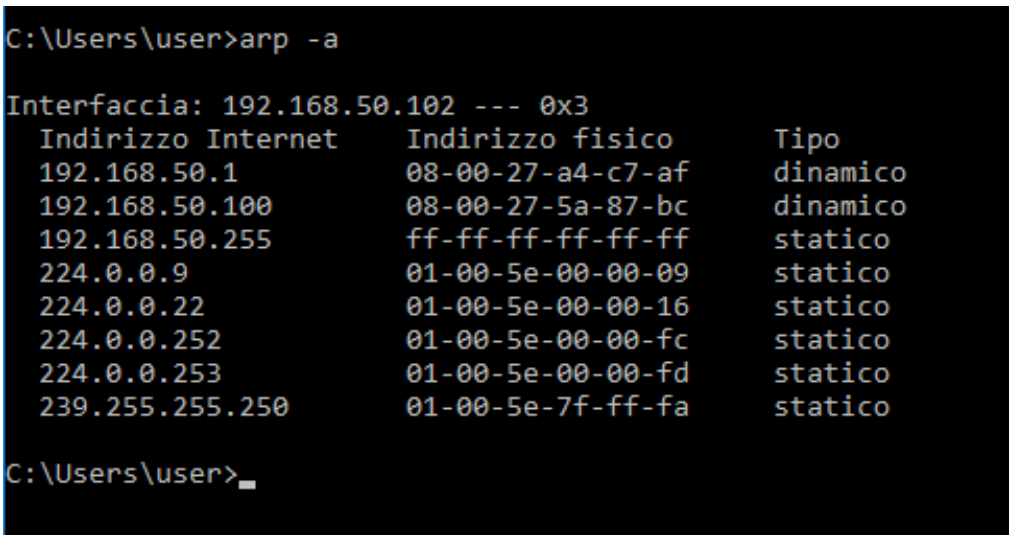
Procedura pratica svolta

Fase	**Attività svolta**
Verifica della rete	Ho verificato gli indirizzi delle macchine e la comunicazione tra Kali, Windows e pfSense.
Individuazione degli host	In Ettercap ho individuato il gateway 192.168.50.1, Windows 192.168.50.102 e Kali 192.168.50.100.
Impostazione dei target	Ho aggiunto il gateway a TARGET1 e Windows a TARGET2.
Cattura ARP iniziale	In Wireshark ho avviato una cattura su eth0 e applicato il filtro arp per osservare le richieste e le risposte.
Controllo della tabella ARP	Su Windows ho usato arp -a per registrare l'associazione iniziale del gateway.
Esame della funzione ARP Poisoning	Ho aperto la funzione ARP Poisoning in Ettercap e controllato la finestra delle

	opzioni. Le schermate disponibili non dimostrano da sole che la sessione sia rimasta attiva in modo continuativo.



Wireshark: cattura ARP e risposta del gateway con il MAC originale.



Windows: controllo della tabella ARP con l'associazione originale del gateway.

```
C:\Users\user>arp -a

Interfaccia: 192.168.50.102 --- 0x3
  Indirizzo Internet    Indirizzo fisico      Tipo
  192.168.50.1          08-00-27-5a-87-bc     dinamico
  192.168.50.100        08-00-27-5a-87-bc     dinamico
  192.168.50.255        ff-ff-ff-ff-ff-ff     statico
  224.0.0.9             01-00-5e-00-00-09     statico
  224.0.0.22            01-00-5e-00-00-16     statico
  224.0.0.252           01-00-5e-00-00-fc     statico
  224.0.0.253           01-00-5e-00-00-fd     statico
  239.255.255.250       01-00-5e-7f-ff-fa     statico

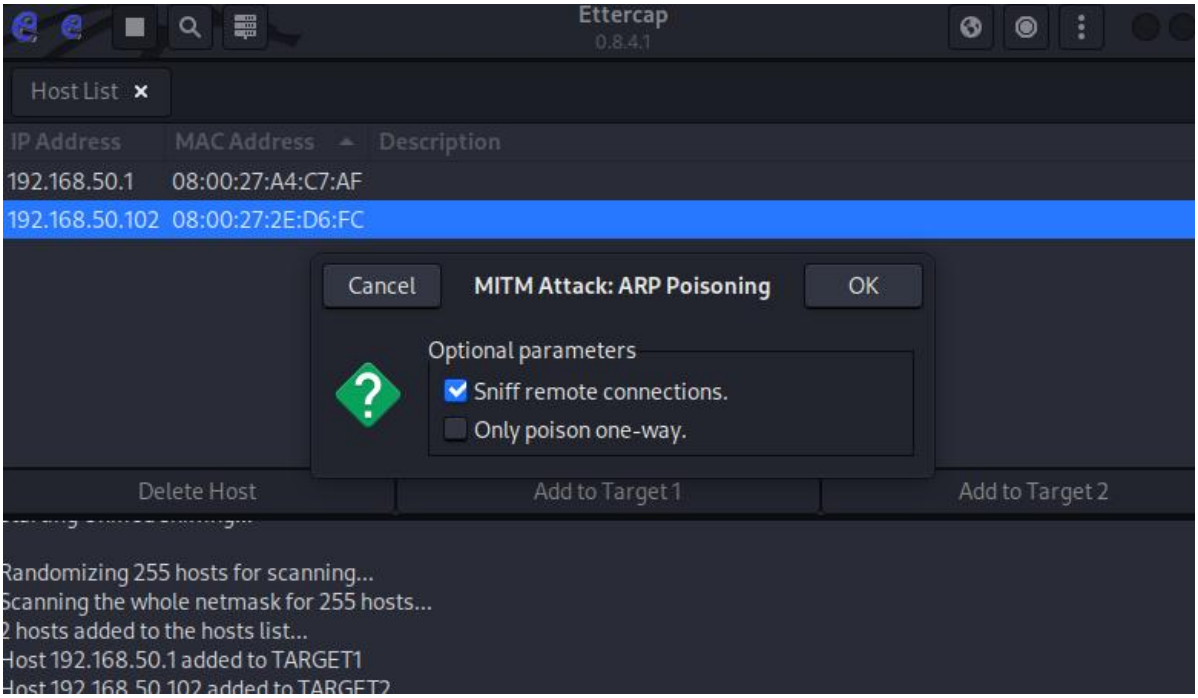
C:\Users\user>
```

Windows: controllo successivo, con il gateway associato temporaneamente al MAC di Kali.

```
C:\Users\user>arp -a

Interfaccia: 192.168.50.102 --- 0x3
  Indirizzo Internet    Indirizzo fisico      Tipo
  192.168.50.1          08-00-27-a4-c7-af     dinamico
  192.168.50.255        ff-ff-ff-ff-ff-ff     statico
  224.0.0.9             01-00-5e-00-00-09     statico
  224.0.0.22            01-00-5e-00-00-16     statico
  224.0.0.252           01-00-5e-00-00-fc     statico
  224.0.0.253           01-00-5e-00-00-fd     statico
  239.255.255.250       01-00-5e-7f-ff-fa     statico
```

Controllo successivo della tabella ARP: l'associazione del gateway risulta nuovamente originale.



Ettercap: finestra delle opzioni della funzione ARP Poisoning.

Valutazione delle contromisure (parte facoltativa)

Contromisura	**Efficacia**	**Impegno per utenti e azienda**
Limitazione delle connessioni anonime	Alta se applicata correttamente	Basso/medio: verificare le applicazioni che dipendono da accessi anonimi.
Aggiornamenti dei sistemi	Alta per le vulnerabilità corrette	Medio: pianificazione, test e manutenzione.
Dynamic ARP Inspection	Alta contro molte forme di ARP Poisoning, se configurata correttamente	Medio/alto: servono switch compatibili e configurazione adeguata.
Monitoraggio con Wireshark e strumenti dedicati	Utile per rilevare e analizzare anomalie	Medio: occorrono tempo e competenze per interpretare gli eventi.
HTTPS e SSH	Alta per proteggere le comunicazioni se usati correttamente	Basso/medio: configurazione e manutenzione dei servizi.

Segmentazione della rete	Riduce la portata di alcuni attacchi	Medio: progettazione e manutenzione della rete.

Considerazioni personali

Con questa pratica ho capito che la sicurezza dipende sia dalla configurazione dei sistemi sia dal monitoraggio della rete. Per ridurre il rischio della Null Session è importante limitare gli accessi anonimi, controllare le condivisioni e mantenere aggiornati i sistemi. Per contrastare l'ARP Poisoning è utile combinare controlli sugli switch, segmentazione e analisi del traffico. Le contromisure richiedono un impegno tecnico, ma possono ridurre il rischio di divulgazione di informazioni, interruzioni e costi di ripristino.

La parte pratica ha permesso di osservare il traffico ARP e un cambiamento temporaneo nell'associazione del gateway sulla tabella ARP di Windows. Non ho invece evidenze sufficienti per dichiarare verificata una sessione MITM completa. Inoltre, non è stato possibile documentare un test pratico della Null Session con gli output disponibili; questa limitazione è riportata per mantenere la relazione fedele alle prove.

Conclusioni

L'attività mi ha permesso di comprendere il funzionamento della Null Session e dell'ARP Poisoning, le condizioni che possono renderli possibili e le principali contromisure. Ho utilizzato Ettercap per individuare gli host e configurare i target, e Wireshark per osservare le comunicazioni ARP. Il confronto delle tabelle ARP ha mostrato un'associazione temporanea del gateway al MAC di Kali, poi tornata al MAC originale di pfSense. Riporto questo risultato come evidenza compatibile con ARP Poisoning, senza estenderlo a conclusioni non dimostrate dalle schermate.